

Báo cáo tích hợp — Đặc tả → Kripke → Sinh mã → CWE/CVE

Đặc tả: smart_lock_formal_verification

Mục lục

1. Đặc tả yêu cầu (Specification)	2
2. Kiểm chứng hình thức (Kripke/CTL)	4
2.1. Sơ đồ chuyển trạng thái	5
3. Mã C sinh ra & Static Checker (lỗi bộ nhớ)	5
4. Trích xuất AST/điều kiện & SMT (Z3)	6
5. Dynamic Fuzzing (hàm Python sinh ra)	7
6. Phân loại CWE/CVE tổng hợp	7
7. Test case truy vết từ đặc tả (tài liệu hóa)	9

1. Đặc tả yêu cầu (Specification)

Đặc tả cho hệ thống khóa thông minh xác thực bằng PIN 4 chữ số, giới hạn 3 lần nhập sai, có các trạng thái LOCKED, UNLOCKING, UNLOCKED và ALARM. Mô hình trừu tượng tách UNLOCKED_AUTH và UNLOCKED_UNAUTH để phân biệt mở khóa hợp lệ với nhánh lỗi trong bản lỗi.

Mã yêu cầu	Loại	Ưu tiên	Nội dung
REQ-1	safety	HIGH	Khóa chỉ được chuyển sang trạng thái mở khi PIN nhập vào khớp PIN đã cấu hình; mọi PIN sai phải giữ cửa khóa.
REQ-2	liveness	HIGH	Khi người dùng nhập đúng PIN 1234 và gửi xác nhận, hệ thống cuối cùng phải đạt trạng thái mở khóa đã xác thực.
REQ-3	safety	HIGH	Sau 3 lần nhập PIN sai liên tiếp, hệ thống phải vào ALARM và cửa vẫn ở trạng thái khóa.
REQ-4	functional	HIGH	Từ ALARM, thao tác ACTION_ADMIN_RESET phải đưa hệ thống về LOCKED, xóa PIN đang nhập và đặt số lần sai về 0.
REQ-5	functional	HIGH	Từ UNLOCKED, thao tác ACTION_LOCK_DOOR phải đưa hệ thống về LOCKED.
REQ-6	functional	MEDIUM	Thao tác ACTION_CANCEL trong lúc nhập PIN phải xóa PIN tạm và quay về LOCKED.
REQ-7	memory	HIGH	Dữ liệu PIN đầu vào khi sao chép vào vùng đệm cố định phải được kiểm tra độ dài để không ghi vượt biên.
REQ-8	memory	HIGH	Bộ nhớ cấp phát cho bản ghi nhật ký xác thực phải được giải phóng đúng một lần sau khi sử dụng.
REQ-9	memory	HIGH	Tài nguyên phiên mở khóa không được giải phóng hai lần.

Mã yêu cầu	Loại	Ưu tiên	Nội dung
REQ-10	memory	HIGH	Hệ thống không được truy cập vùng nhớ chứa PIN sau khi vùng nhớ đó đã được giải phóng.
REQ-11	safety	HIGH	Các phép cộng bộ đếm lần thử, sự kiện mở khóa và nhật ký phải được kiểm tra tràn số nguyên.
REQ-12	functional	MEDIUM	Hàm tính tỷ lệ lần xác thực thất bại phải xử lý trường hợp tổng số lần thử bằng 0.
REQ-13	functional	LOW	Hàm kiểm thử mã mở khóa đặc biệt phải chỉ trả về thành công khi cặp giá trị bí mật là 12 và 34.
NFR-1	non_functional	HIGH	Mỗi thao tác nhập hoặc gửi PIN phải được xử lý trong không quá 50 ms trên máy kiểm thử tham chiếu.
NFR-2	non_functional	HIGH	ACTION_LOCK_DOOR phải hoàn tất chuyển trạng thái trong không quá 20 ms trên máy kiểm thử tham chiếu.
NFR-3	non_functional	MEDIUM	Bộ mô phỏng phải xử lý tối thiểu 100 hành động trạng thái mỗi giây.
NFR-4	non_functional	HIGH	Bộ test tự động phải bao phủ 100% cạnh chuyển trạng thái đã khai báo trong mô hình Kripke.
NFR-5	non_functional	MEDIUM	Nhật ký kiểm thử phải lưu được tối thiểu 1000 sự kiện xác thực gần nhất.
NFR-6	non_functional	MEDIUM	Kết quả mô hình hóa phải lặp lại giống nhau trong 1000 lần chạy cùng một tập đầu vào.
CON-1	constraint	HIGH	Phần cài đặt chính của khóa thông minh sử dụng C++17.

Mã yêu cầu	Loại	Ưu tiên	Nội dung
CON-2	constraint	HIGH	PIN hợp lệ phải gồm đúng 4 ký tự số ASCII; kích thước dữ liệu PIN dùng cho kiểm thử vùng đệm là 4 byte.
CON-3	constraint	HIGH	Ngưỡng khóa báo động max_attempts được cố định là 3 lần nhập sai liên tiếp.
CON-4	constraint	HIGH	Máy trạng thái cài đặt chỉ có bốn trạng thái nghiệp vụ: LOCKED, UNLOCKING, UNLOCKED và ALARM.
CON-5	constraint	HIGH	Chỉ ACTION_ADMIN_RESET được phép rời ALARM; các hành động khác tại ALARM tạo self-loop.
CON-6	constraint	MEDIUM	Cài đặt sản phẩm phải dùng std::string cho PIN và không quản lý PIN bằng con trỏ thô; mã C sinh ra chỉ dùng làm mẫu kiểm thử CWE.
CON-7	constraint	LOW	Hai nửa của mã mở khóa đặc biệt dùng trong kiểm thử concolic là số nguyên 16 bit không dấu.

2. Kiểm chứng hình thức (Kripke/CTL)

Trạng thái deadlock: không có

Công thức CTL	Kết quả	Trạng thái thỏa
AG(!violation)	VI PHẠM	-
AG(unlocked -> authenticated)	VI PHẠM	-
AG(alarm -> locked)	VI PHẠM	-
EF(unlocked)	ĐÚNG	ALARM, LOCKED, UNLOCKED_AUTH, UNLOCKED_UNAUTH, UNLOCKING
AG(unlocking -> AF(locked unlocked alarm))	VI PHẠM	-
EF(alarm)	ĐÚNG	ALARM, LOCKED, UNLOCKED_AUTH, UNLOCKED_UNAUTH, UNLOCKING

Mutual exclusion: OK (trạng thái nguy hiểm: không có)

2.1. Sơ đồ chuyển trạng thái

Sơ đồ: Mô hình chính: smart_lock_formal_verification

Mã TikZ (LaTeX) — dán trực tiếp vào tài liệu LaTeX có `\usepackage{tikz}` để biên dịch thành hình vector, thay cho ảnh tĩnh:

```
% Mô hình chính: smart_lock_formal_verification
\begin{tikzpicture}
every node/.style={draw, circle, inner sep=2pt,
minimum size=8mm, align=center, font=\scriptsize},
->, >=stealth, thick, auto
]
\node[fill=red!35] (nd_UNLOCKED_UNAUTH) at (-1.48,2.20) {UNLOCKED\_UNAUTH\\{\tiny
unauthorized\_unlock,unlocked,violation}};
\node[fill=gray!15] (nd_UNLOCKED_AUTH) at (1.77,-1.35) {UNLOCKED\_AUTH\\{\tiny authenticated,safe,unlocked}};
\node[fill=gray!15] (nd_ALARM) at (-0.43,-1.79) {ALARM\\{\tiny alarm,failed\_max,locked,safe}};
\node[fill=gray!15] (nd_UNLOCKING) at (-0.64,-0.26) {UNLOCKING\\{\tiny locked,safe,unlocking}};
\node[fill=blue!25] (nd_LOCKED) at (0.78,1.19) {LOCKED\\{\tiny locked,safe}};
\draw (nd_UNLOCKED_UNAUTH) -- (nd_UNLOCKED_UNAUTH);
\draw (nd_UNLOCKED_UNAUTH) -- (nd_LOCKED);
\draw (nd_UNLOCKED_AUTH) -- (nd_UNLOCKED_AUTH);
\draw (nd_UNLOCKED_AUTH) -- (nd_LOCKED);
\draw (nd_ALARM) -- (nd_ALARM);
\draw (nd_ALARM) -- (nd_LOCKED);
\draw (nd_UNLOCKING) -- (nd_ALARM);
\draw (nd_UNLOCKING) -- (nd_UNLOCKED_UNAUTH);
\draw (nd_UNLOCKING) -- (nd_LOCKED);
\draw (nd_UNLOCKING) -- (nd_UNLOCKING);
\draw (nd_UNLOCKING) -- (nd_UNLOCKED_AUTH);
\draw (nd_LOCKED) -- (nd_UNLOCKING);
\draw (nd_LOCKED) -- (nd_LOCKED);
\end{tikzpicture}
```

3. Mã C sinh ra & Static Checker (lỗi bộ nhớ)

Mã C sinh từ đặc tả

```
#include <stdio.h>
#include <stdlib.h>
#include <string.h>

/* sinh từ đặc tả 'smart_lock_formal_verification', hàm 'parse_pin_input', kind='buffer_copy' */
void parse_pin_input(const char *raw_pin) {
char buffer[4];
strcpy(buffer, raw_pin); /* sinh từ đặc tả: buffer-overflow */
printf("%s\n", buffer);
}

/* sinh từ đặc tả 'smart_lock_formal_verification', hàm 'write_auth_log', kind='alloc_release' */
void write_auth_log(void) {
int *buf = malloc(sizeof(int) * 32);
buf[0] = 0;
/* sinh từ đặc tả: memory-leak (thiếu free) */
}

/* sinh từ đặc tả 'smart_lock_formal_verification', hàm 'close_unlock_session', kind='alloc_release' */
void close_unlock_session(void) {
int *buf = malloc(sizeof(int) * 4);
buf[0] = 0;
free(buf);
free(buf); /* sinh từ đặc tả: double-free */
}

/* sinh từ đặc tả 'smart_lock_formal_verification', hàm 'release_pin_buffer', kind='alloc_release' */
void release_pin_buffer(void) {
int *buf = malloc(sizeof(int) * 8);
buf[0] = 0;
```

```
free(buf);
buf[0] = 1; /* sinh từ đặc tả: use-after-free */
}

/* sinh từ đặc tả 'smart_lock_formal_verification', hàm 'sum_failed_attempts', kind='arithmetic' */
int sum_failed_attempts(int current_attempts, int additional_attempts) {
return current_attempts + additional_attempts;
}
```

Dòng	Mức độ	Loại lỗi	Mô tả
8	HIGH	dangerous-function	Sử dụng hàm không an toàn 'strcpy()' — dễ gây buffer overflow. Gợi ý: dùng strncpy thay the.
14	MEDIUM	memory-leak	Con trỏ 'buf' được cấp phát (malloc/calloc/realloc) nhưng không thấy free() trong hàm write_auth_log() — nghi ngờ rò rỉ bộ nhớ
24	HIGH	double-free	Double-free trên con trỏ 'buf' (đã free() tại dòng 23) trong hàm close_unlock_session()
32	HIGH	use-after-free	Khả năng sử dụng con trỏ 'buf' sau khi free() (freed tại dòng 31) trong hàm release_pin_buffer()

4. Trích xuất AST/điều kiện & SMT (Z3)

Hàm	Biến	Điều kiện	Vòng lặp	Độ phức tạp McCabe	Độ sâu lồng nhau
parse_pin_input	['buffer']	[]	[]	1	1
write_auth_log	['buf']	[]	[]	1	1
close_unlock_session	['buf']	[]	[]	1	1
release_pin_buffer	['buf']	[]	[]	1	1
sum_failed_attempts	[]	[]	[]	1	1
failed_attempt_ratio	[]	[]	[]	1	1
smart_lock_unlock_code	[]	['code_a == 12', 'code_b == 34']	[]	3	3

Kiểm tra	Kết quả SMT	Model (nếu SAT)
failed_attempt_counter	sat	{'current_attempts': 32768, 'additional_attempts': 0}

Kiểm tra	Kết quả SMT	Model (nếu SAT)
failed_attempt_counter (int32 overflow?)	sat	{'current_attempts': 1, 'additional_attempts': 2147483647}
pin_digit_counter	sat	{'entered_digits': 32768, 'incoming_digits': 0}
pin_digit_counter (int32 overflow?)	sat	{'entered_digits': -1, 'incoming_digits': -2147483648}
auth_log_counter	sat	{'successful_events': 2000000001, 'failed_events': 0}
auth_log_counter (int32 overflow?)	sat	{'successful_events': -1, 'failed_events': -2147483648}
unlock_event_counter	sat	{'local_unlocks': 2000000001, 'remote_unlocks': 0}
unlock_event_counter (int32 overflow?)	sat	{'local_unlocks': -1, 'remote_unlocks': -2147483648}
admin_reset_counter	sat	{'scheduled_resets': 65536, 'emergency_resets': 0}
admin_reset_counter (int32 overflow?)	sat	{'scheduled_resets': -1, 'emergency_resets': -2147483648}

5. Dynamic Fuzzing (hàm Python sinh ra)

Hàm Python 'failed_attempt_ratio'

```
def failed_attempt_ratio(failed_attempts, total_attempts):
    return failed_attempts // total_attempts
```

Hàm Python 'smart_lock_unlock_code'

```
def smart_lock_unlock_code(code_a, code_b):
    if code_a == 12:
    if code_b == 34:
        raise ValueError('magic value reached')
    return code_a + code_b
```

Hàm	Kết quả fuzzing
failed_attempt_ratio	black-box: 11/300 lần crash
smart_lock_unlock_code	concolic: crash_input={'code_a': 12, 'code_b': 34} sau 3 lần thử

6. Phân loại CWE/CVE tổng hợp

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch1	cong thuc AG(!violation)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch1	cong thuc AG(unlocked -> authenticated)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(alarm -> locked)	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch1	cong thuc AG(unlocking -> AF(locked unlocked alarm))	safety-property-violation	CWE-693 — Protection Mechanism Failure	-
ch2	dong 8	dangerous-function	CWE-120 — Buffer Copy without Checking Size of Input	CVE-2003-0352 (2003)
ch2	dong 14	memory-leak	CWE-401 — Missing Release of Memory after Effective Lifetime	-
ch2	dong 24	double-free	CWE-415 — Double Free	-
ch2	dong 32	use-after-free	CWE-416 — Use After Free	CVE-2019-0708 (2019)
ch3	failed_attempt_counter	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	pin_digit_counter	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	auth_log_counter	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	unlock_event_counter	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)
ch3	admin_reset_counter	integer-overflow	CWE-190 — Integer Overflow or Wraparound	CVE-2016-5195 (2016)

Nguồn	Vị trí	Loại phát hiện	CWE	Ví dụ CVE minh họa
ch4	failed_attempt_ratio	uncontrolled-crash	CWE-248 — Uncaught Exception	-
ch4	smart_lock_unlock_code	uncontrolled-crash	CWE-248 — Uncaught Exception	-

7. Test case truy vết từ đặc tả (tài liệu hóa)

ID	Ưu tiên	Tiêu đề	Truy vết yêu cầu	Kết quả mong đợi
TC-1	HIGH	PIN sai không được mở khóa	REQ-1	Hệ thống chuẩn ở LOCKED và failed_attempts = 1. Bản buggy thất bại vì đi tới UNLOCKED_UNAUTH/violation.
TC-2	HIGH	PIN đúng mở khóa	REQ-2	Đạt UNLOCKED_AUTH; có nhãn unlocked, authenticated, safe; failed_attempts = 0.
TC-3	HIGH	Ba lần sai kích hoạt ALARM	REQ-3	Hai lần đầu quay về LOCKED; lần thứ ba vào ALARM; cửa vẫn locked và failed_max đúng.
TC-4	HIGH	Quản trị viên đặt lại báo động	REQ-4	Trở về LOCKED; failed_attempts = 0; PIN tạm rỗng.
TC-5	HIGH	Khóa cửa sau khi mở	REQ-5	Trở về LOCKED.
TC-6	MEDIUM	Hủy nhập PIN	REQ-6	PIN tạm bị xóa và hệ thống về LOCKED.
TC-7	HIGH	Kiểm chứng thuộc tính mở khóa có xác thực	REQ-1	Mô hình buggy sinh phản ví dụ qua UNLOCKED_UNAUTH; mô hình đã sửa phải thỏa cả hai công thức.
TC-8	HIGH	Quét bốn lỗi bộ nhớ	REQ-7, REQ-8, REQ-9, REQ-10	Phát hiện lần lượt buffer-overflow, memory-leak, double-free và use-after-free theo cấu hình.
TC-9	HIGH	Tìm đầu vào gây tràn bộ đếm	REQ-11	Mỗi cấu hình có ít nhất một nghiệm thỏa điều kiện vượt ngưỡng tương ứng.
TC-10	MEDIUM	Tổng số lần thử bằng 0	REQ-12	Hàm từ chối phép chia cho 0 bằng lỗi có kiểm soát; không trả về giá trị sai.
TC-11	LOW	Tìm mã mở khóa đặc biệt	REQ-13	Tìm được cặp code_a = 12 và code_b = 34; các cặp khác không được chấp nhận.
TC-12	MEDIUM	Bao phủ toàn bộ chuyển trạng thái	NFR-4	Tỷ lệ bao phủ cạnh chuyển trạng thái đạt 100%.